

Week:5 Security Testing & Vulnerability

Analysis Report

Muhammad Ameerque

DHC-ID: DHC-253

Domain: Software Quality Assurance

1. Introduction

This report presents the results of basic web application security testing conducted as part of Week 5 of the Software Quality Assurance course. The purpose of this activity was to understand common web application vulnerabilities and how security testing tools can identify them.

The testing was conducted using **OWASP ZAP**, an open-source security testing tool developed by the **Open Web Application Security Project**.

The test target was a deliberately vulnerable web application used for educational purposes.

2. Tools Used

Tool	Purpose
OWASP ZAP	Web vulnerability scanning
Web Browser	Access the web application
Demo Test Website	Safe environment for security testing

File
Edit
View
Analyse
Report
Tools
Import
Export
Online
Help
Untitled Session - Untitl...

Standard Mode

Sites

Contexts

Default Context

Sites

Quick Start

Request

Response

Requester

Welco...



ZAP is an easy to use integrated penetration testing tool for finding vulnerabilities in web applications.

If you are new to ZAP then it is best to start with one of the options below.







News

Learn all about 2.17.0 in the ZAP blog post

Learn More

History

Search

Alerts

Output

Filter: OFF

Export

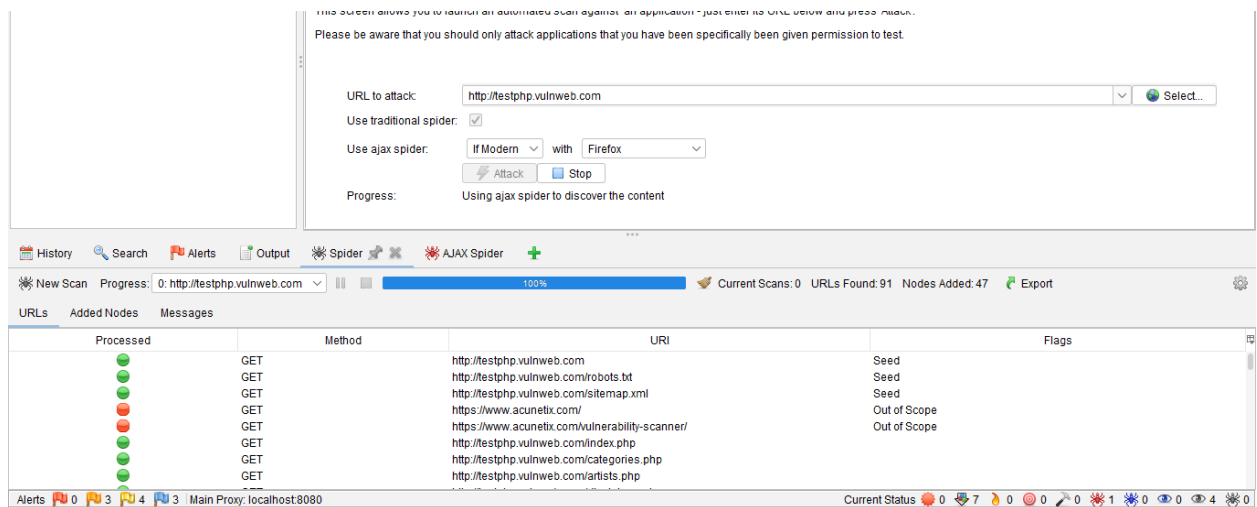
ID	Sou...	Req. Timesta...	Met...	URL	Co...	Reason	R...	Size Resp. ...	Highest ...	N...	Tags
----	--------	-----------------	--------	-----	-------	--------	------	----------------	-------------	------	------

Alerts
0
0
0
0
Main Proxy: localhost:8080
Current Status
0
17
0
0
0
0
0
0
0
0
0
0
0
0
0
0

3. Testing Methodology

The following steps were performed during security testing:

1. Installed OWASP ZAP.
2. Launched the tool and entered the target website URL.
3. Performed passive scanning to detect vulnerabilities.
4. Tested input fields using malicious payloads.
5. Checked authentication and session behavior.
6. Documented vulnerabilities and recommended fixes.



4. Vulnerability Findings

Vulnerability 1 – Cross Site Scripting (XSS)

Vulnerability ID: VULN-001

Severity: High

Description

Cross Site Scripting occurs when an application allows users to inject malicious scripts into web pages viewed by other users.

Steps to Reproduce

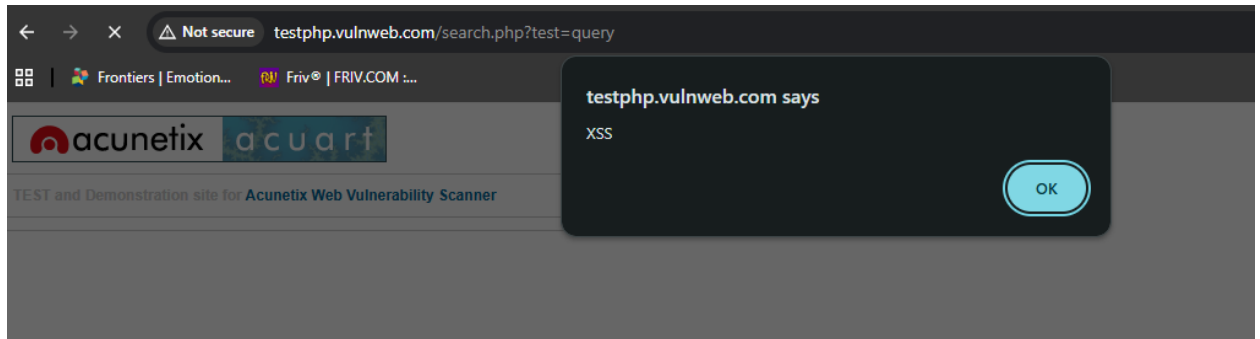
1. Open the search field.
2. Enter the payload:

```
<script>alert('XSS')</script>
```

3. Submit the request.

Evidence

XSS Screenshot



Suggested Fix

- Validate user inputs
- Escape HTML characters
- Use output encoding

Vulnerability 2 – SQL Injection

Vulnerability ID: VULN-002

Severity: Critical

Description

SQL Injection allows attackers to manipulate database queries through malicious input.

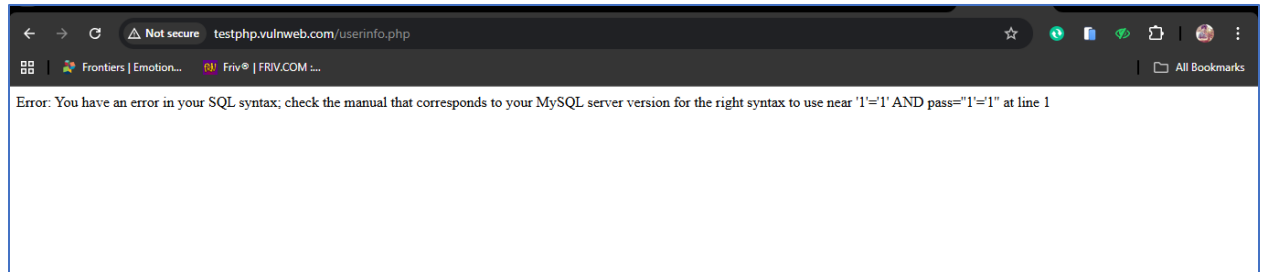
Steps to Reproduce

1. Open login page
2. Enter payload:

```
' OR '1'='1
```

3. Attempt login

SQL Injection Screenshot



Suggested Fix

- Use parameterized queries
- Use prepared statements
- Validate user inputs

Vulnerability 3 – Broken Authentication

Vulnerability ID: VULN-003

Severity: Medium

Description

Improper authentication mechanisms may allow unauthorized users to access protected pages.

Login/Session Screenshot

The screenshot shows a web browser window with the address bar displaying 'testphp.vulnweb.com/userinfo.php'. The page features the Acunetix and acuart logos at the top. Below the logos, there is a navigation bar with links: home, categories, artists, disclaimer, your cart, guestbook, AJAX Demo, and Logout test. On the left side, there is a sidebar with a search bar, a 'go' button, and links for 'Browse categories', 'Browse artists', 'Your cart', 'Signup', 'Your profile', 'Our guestbook', and 'AJAX Demo'. Below these links are 'Links' for 'Security art', 'PHP scanner', 'PHP vuln help', and 'Fractal Explorer'. The main content area is titled 'John Smith (test)' and contains the text 'On this page you can visualize or edit you user information.' Below this text is a form with the following fields: Name (John Smith), Credit card number (1234-5678-2300-9000), E-Mail (email@email.com), Phone number (2323345), and Address (21 street). There is an 'update' button at the bottom right of the form. Below the form, there is a message: 'You have 0 items in your cart. You visualize you cart here.' At the bottom of the page, there is a footer with links: About Us, Privacy Policy, Contact Us, and ©2019 Acunetix Ltd.

TEST and Demonstration site for **Acunetix Web Vulnerability Scanner**

home | categories | artists | disclaimer | your cart | guestbook | AJAX Demo | Logout test

search art
 go

Browse categories
Browse artists
Your cart
Signup
Your profile
Our guestbook
AJAX Demo

Links
Security art
PHP scanner
PHP vuln help
Fractal Explorer

John Smith (test)

On this page you can visualize or edit you user information.

Name: John Smith
Credit card number: 1234-5678-2300-9000
E-Mail: email@email.com
Phone number: 2323345
Address: 21 street

update

You have 0 items in your cart. You visualize you cart [here](#).

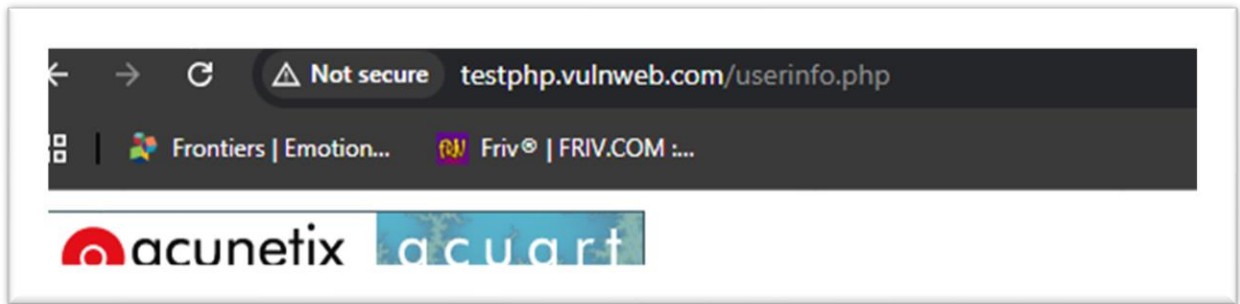
About Us | Privacy Policy | Contact Us | ©2019 Acunetix Ltd

Suggested Fix

- Implement secure session management
- Invalidate session tokens after logout

Vulnerability 4 – Sensitive Data Exposure

HTTP Screenshot



Suggested Fix

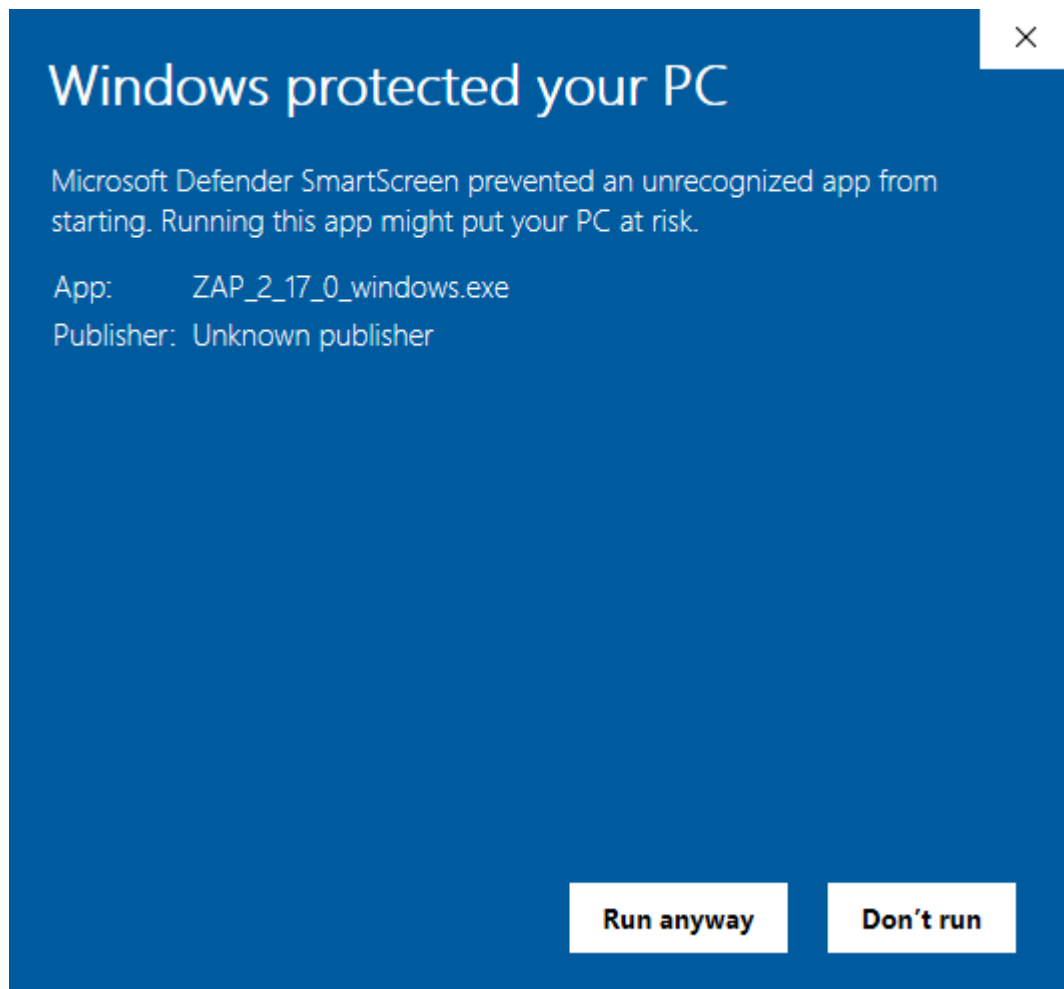
- Use HTTPS
- Encrypt sensitive data

5. Summary Table

Vulnerability	Severity
Cross Site Scripting	High
SQL Injection	Critical
Broken Authentication	Medium
Sensitive Data Exposure	High
Security Misconfiguration	Medium

6. Conclusion

This security testing exercise demonstrated how common vulnerabilities can exist in web applications. By using **OWASP ZAP** and following guidelines from the **OWASP**, it is possible to identify and mitigate many common security risks. Proper input validation, secure authentication mechanisms, and secure configuration practices are essential to protect web applications.



 install4j Wizard — □ ×



Zed Attack Proxy by Checkmarx is preparing the install4j Wizard which will guide you through the rest of the setup process.



Cancel